

CLIENT DELIVERABLE

CRM Lite — Privacy Compliance

Systack Documentation

ROLE	COLOR	HEX
Headers, CTAs	Navy	 #001a2d
Navy Light	Navy Light	 #002845
Secondary accents	Teal	 #007da9
Primary buttons, links	Cyan	 #00a1db
Gradients	Cyan Bright	 #00c5e0
Backgrounds	Gray 50	 #f8fafc
Cards	Gray 100	 #f1f5f9
Borders	Gray 200	 #e2e8f0
Muted text	Gray 400	 #94a3b8
Body text	Gray 600	 #475569
Headings	Gray 800	 #1e293b
Success	Green	 #22c55e
Error	Red	 #ef4444
Accent highlights	Purple	 #8b5cf6

CRM Lite — Privacy Compliance

Automation ID: `crm-lite`**Version:** 1.0**Status:** Draft — Planning**Date:** 2026-06-16**Builder:** SOL / Assembly

1. Data Collected

FIELD	PURPOSE	RETENTION
Name	Personalization, booking	Duration of customer relationship
Email	Communication, identification	Duration of customer relationship
Phone	SMS reminders, contact	Duration of customer relationship
Visit history	Service personalization	24 months after last visit

FIELD	PURPOSE	RETENTION
Spend history	Loyalty tracking	24 months after last visit
Service preferences	Rebooking suggestions	24 months after last visit
Provider preference	Booking optimization	24 months after last visit

2. Data NOT Collected

- Payment card details (handled by Square)
- Location data
- Browser history
- Social media profiles
- Demographic data (age, gender, etc.)

3. Customer Rights

RIGHT	IMPLEMENTATION
Access	Customer can request their profile data via email
Correction	Profile updated on each booking; corrections via support
Deletion	Full profile deletion on verified request
Portability	JSON export of all profile data
Objection	Opt-out of personalization (profile marked <code>do_not_track</code>)

4. Data Security

MEASURE	IMPLEMENTATION
Encryption at rest	Postgres on encrypted disk
Access control	Local-only database, no external exposure
Authentication	Profile API requires internal auth
Audit log	Profile access and modifications logged

5. Regulatory Compliance

GDPR (EU Customers)

- Lawful basis: Legitimate interest (service relationship)
- Data stored: Locally, not transferred internationally
- DPO: Not required (small-scale, non-sensitive data)

- Breach notification: Within 72 hours if applicable

CCPA (California Customers)

- Right to know: Provide profile on request
- Right to delete: Delete profile on verified request
- Do not sell: Data never sold or shared
- No discrimination: Same service regardless of privacy choices

6. Data Retention Schedule

DATA CATEGORY	RETENTION PERIOD	ACTION AFTER
Active customer (visited < 12 months)	Full profile	Keep
Inactive customer (12–24 months)	Full profile	Keep, flag for review
Dormant customer (> 24 months)	Anonymize	Remove PII, keep aggregate stats
Deletion requested	Immediate	Full deletion within 30 days

7. Compliance Checklist

- ☐ Privacy policy updated to include CRM data usage
- ☐ Customer consent obtained (booking terms)
- ☐ Data deletion endpoint functional
- ☐ Data export endpoint functional
- ☐ Auto-anonymization cron active
- ☐ Access logs maintained
- ☐ Breach response plan documented